COMPTIA PENTEST+ · PT0-003 · STUDY GUIDE

Domain 4 — Attacks & Exploits

Organized by attack surface, with the four-slot framework: *what it is* → *tool* → *indicator* → *remediation*.

Domain 4 is the most heavily weighted domain on the exam

Domain 4 is the biggest and *broadest* objective on PT0-003 — not deep in one place, but wide across many attack surfaces. Studying it as one long list is what makes it feel impossible. This guide hangs every attack on the surface it targets, so when a scenario question appears your first thought is "this is a *web* attack" or "this is a *network* attack," and half the answer is already narrowed.

The four-slot framework — apply it to every single attack:

- **What it is** — the mechanism, in one line. Understanding *why* it works lets you rebuild details and spot CompTIA's "almost right" distractors.
- **Tool** — what you'd run. Most items only require *recognition*, not blank recall.
- **Indicator** — the evidence/output that proves it worked (what a PBQ shows you).
- **Remediation** — the fix. CompTIA loves asking for the mitigation, not the attack.

Anchor web attacks to the **OWASP Top 10** and everything else to **MITRE ATT&CK** — those two frameworks are essentially CompTIA's source outline.

The eight attack surfaces (your master map)

1 · Network | 2 · Wireless | 3 · Web Application | 4 · Cloud | 5 · Host / Privilege Escalation | 6 · Authentication & Credentials | 7 · Social Engineering & Physical | 8 · Specialized Systems

Confirm the weighting. Domain 4 is "Attacks and Exploits" and the largest domain, but pull the official CompTIA PT0-003 exam objectives PDF for the exact sub-objective list and percentages before you plan your study hours — it's the authoritative source and gets revised.

1 Network Attacks

Attacks against protocols, name resolution, and traffic on the wire. The highest-yield theme here is **on-path / poisoning → relay**: trick a host into talking to you, then capture or relay its authentication.

Attack	What it is	Tool(s)	Indicator	Remediation
ARP spoofing / on-path (MITM)	Forge ARP replies to associate your MAC with another host's IP, sitting between victim and gateway.	Ettercap, Bettercap, `arpspoof`	Duplicate MAC for an IP; gratuitous ARP floods.	Dynamic ARP Inspection, static ARP, port security.

Attack	What it is	Tool(s)	Indicator	Remediation
LLMNR / NBT-NS / mDNS poisoning	Answer broadcast name-resolution requests to capture NetNTLM hashes.	Responder, Inveigh	Captured NetNTLMv2 hashes in Responder output.	Disable LLMNR/NBT-NS via GPO; enable SMB signing.
NTLM relay	Relay captured NTLM auth to another host to authenticate as the victim (no cracking needed).	Impacket `ntlmrelayx.py`	Auth succeeds on relayed target; new session/shell.	Enforce SMB/LDAP signing; disable NTLM where possible.
DNS cache poisoning / spoofing	Inject forged DNS records so victims resolve to attacker hosts.	Ettercap, dnsspoof	Wrong IP returned for a known domain.	DNSSEC, restrict recursion, source-port randomization.
DNS zone transfer	Request full zone (AXFR) from a misconfigured DNS server to map the network.	`dig axfr`, `host -l`, dnsrecon	Full list of records dumped.	Restrict AXFR to authorized secondaries.
DHCP starvation / rogue DHCP	Exhaust the DHCP pool, then answer as a rogue server to control gateway/DNS.	Yersinia, dhcpstarv	Pool exhaustion; clients get attacker gateway.	DHCP snooping, port security.
VLAN hopping	Reach other VLANs via switch-spoofing (DTP) or double-tagging.	Yersinia, Scapy	Traffic seen on VLANs you shouldn't reach.	Disable DTP, don't use VLAN 1 as native, lock trunks.
Packet crafting	Hand-build packets to test filters, spoof, or trigger conditions.	Scapy, hping3	Custom responses / filter behavior.	Ingress/egress filtering, stateful inspection.
DoS / DDoS / amplification	Exhaust resources; reflect off DNS/NTP/memcached for amplification.	hping3, LOIC (concept)	Resource exhaustion, service unavailable.	Rate limiting, upstream scrubbing, anti-spoofing (BCP38).
SMB attacks	Exploit shares, null sessions, and unsigned SMB for access/relay.	enum4linux, CrackMapExec, smbclient	Anonymous share listing; writable shares.	Require SMB signing, disable SMBv1, restrict null sessions.

Highest yield: the `Responder → ntlmrelayx` chain and knowing that **SMB signing** is the mitigation that breaks NTLM relay. This shows up constantly.

---

2 Wireless Attacks

Mostly the **Aircrack-ng** workflow: monitor → capture → deauth to force a handshake → crack. Know the encryption generations (WEP → WPA/WPA2 → WPA3) and the rogue-AP family.

Attack	What it is	Tool(s)	Indicator	Remediation
WPA/WPA2 handshake capture	Capture the 4-way handshake, then crack the PSK offline.	airodump-ng + aircrack-ng / Hashcat	Handshake captured in the `.cap`.	Long random passphrase; move to WPA3.
Deauthentication	Spoofed deauth frames kick clients off to force a re-handshake (also a DoS).	aireplay-ng, mdk4	Clients drop and reconnect.	802.11w (Protected Management Frames).
PMKID attack	Grab the PMKID from the first frame — no client needed.	hcxdumptool → hcxpcapngtool → Hashcat	PMKID hash captured.	Strong PSK; WPA3.
WEP cracking	Statistical IV weakness allows fast key recovery.	aircrack-ng	Key recovered after enough IVs.	Retire WEP entirely.
WPS attacks	Brute-force / Pixie-Dust the WPS PIN to recover the PSK.	Reaver, Bully	PIN and PSK recovered.	Disable WPS.
Evil twin / rogue AP	Clone a legit SSID to lure clients and capture creds.	hostapd, Wifiphisher, Airgeddon	Clients associate to your AP; captured creds.	802.1X/EAP-TLS, WIDS, verify BSSIDs.
Captive-portal / karma	Fake portal or auto-respond to probe requests to harvest credentials.	Wifiphisher, eaphammer	Submitted portal credentials.	Client-side network validation; disable auto-join.
Bluetooth attacks	Bluejacking (spam), bluesnarfing (data theft), BlueBorne (RCE class).	bluetoothctl, btlejack	Unauthorized pairing / data access.	Non-discoverable, patch, disable when unused.
RFID / NFC cloning	Read and clone access badges.	Proxmark3, Flipper Zero	Cloned badge grants entry.	Encrypted/rolling credentials, MFA at doors.

Core Aircrack-ng workflow (know this sequence cold)

```
airmon-ng start wlan0               # enable monitor mode (wlan0mon)
airodump-ng wlan0mon                # find target BSSID + channel
airodump-ng -c 6 --bssid AA:.. -w cap wlan0mon   # capture on channel
aireplay-ng --deauth 5 -a AA:.. wlan0mon         # force handshake
aircrack-ng -w wordlist.txt cap.cap  # crack the PSK offline
```

---

3 Web Application Attacks ★ heaviest sub-area

The meatiest chunk of Domain 4. Anchor it to the **OWASP Top 10**. Master the injection family and access-control flaws first. **Burp Suite** is the through-line tool for nearly all of these.

Attack	What it is	Tool(s)	Indicator	Remediation
SQL injection	Inject SQL via input to read/modify the DB. Types: union, error-based, blind (boolean), time-based.	sqlmap, Burp	DB errors, extracted rows, time delays.	Parameterized queries / prepared statements; least-priv DB user.
Cross-site scripting (XSS)	Inject script into pages. Stored (persisted), Reflected (in request), DOM-based (client-side).	Burp, XSStrike	Your JS executes in the victim's browser.	Output encoding, CSP, input validation.
CSRF	Force a logged-in victim's browser to send an unwanted authenticated request.	Burp CSRF PoC generator	State change with no valid anti-CSRF token.	Anti-CSRF tokens, SameSite cookies.
SSRF	Make the server request an attacker-chosen URL — often to hit internal/cloud metadata.	Burp, Gopherus	Server fetches internal resources.	Allowlist egress, block link-local, validate URLs.
XXE	Abuse XML external entities to read files or reach internal services.	Burp	File contents / SSRF via XML parse.	Disable external entities/DTDs in the parser.
Command injection	Input reaches an OS shell, running arbitrary commands.	Burp, commix	Command output in the response.	Avoid shell calls; validate input; use safe APIs.
Path traversal / LFI / RFI	`../` to read arbitrary files, include local or remote files for execution.	Burp, wfuzz	Contents of `/etc/passwd`; remote include runs.	Canonicalize paths, allowlist, disable remote includes.

Attack	What it is	Tool(s)	Indicator	Remediation
IDOR / broken access control	Change an identifier to access objects you shouldn't.	Burp (repeat/intruder)	Another user's data returned.	Server-side authorization checks per object.
Authentication / session attacks	Bypass logic, hijack or fixate sessions, weak tokens.	Burp, Hydra	Access without valid creds; reused session ID.	Regenerate session on login, secure cookies, MFA.
File upload flaws	Upload a web shell / malicious file the server executes.	Burp, weevely (concept)	Uploaded file runs server-side.	Validate type/content, store outside webroot, no execute.
SSTI	Inject template syntax that the engine evaluates → RCE.	tplmap, Burp	Math/expression evaluates in output.	Sandbox templates, don't pass user input to engine.
Insecure deserialization	Feed crafted serialized objects to trigger code execution.	ysoserial, Burp	Unexpected code execution on parse.	Don't deserialize untrusted data; integrity checks.
API attacks	Abuse REST/GraphQL: BOLA/IDOR, mass assignment, excessive data exposure.	Burp, Postman	Unauthorized objects/fields returned.	Per-object authz, schema validation, rate limits.

Discovery + workhorse tools

gobuster / feroxbuster **dirb** content discovery **nikto** quick server scan **wfuzz / ffuf** fuzzing **OWASP ZAP** free proxy **Burp Suite** the primary interception/testing tool

> **Distractor watch:** the classic exam trap is **stored vs reflected vs DOM** XSS, and picking **parameterized queries** (not "input validation" or "WAF") as the *best* SQLi fix.

---

4 Cloud Attacks

Cloud pentesting is mostly **misconfiguration and identity**, not memory-corruption exploits. The signature move: chain an app flaw (often SSRF) into the **instance metadata service** to steal credentials.

Attack	What it is	Tool(s)	Indicator	Remediation
Public storage buckets	Misconfigured S3/Blob/GCS buckets expose or accept data.	ScoutSuite, s3scanner, CloudBrute	Listable/writable bucket contents.	Block public access, least-priv policies, encryption.
Metadata service (IMDS) abuse	SSRF to `169.254.169.254` to steal instance role credentials.	Burp, curl	Temporary cloud creds returned.	Enforce IMDSv2, block link-local egress.
IAM misconfig / privesc	Over-permissive roles/policies let you escalate.	Pacu, Prowler, PMapper	Escalation path (e.g., `iam:PassRole`).	Least privilege, remove wildcard policies, review roles.
Exposed keys / secrets	Access keys leaked in code, repos, or metadata.	truffleHog, gitleaks	Valid keys found and usable.	Secret scanning, rotation, use short-lived creds.
Container / K8s attacks	Exposed Docker/kubelet API, privileged containers, escape to host.	kube-hunter, kubectl, amicontained	Host access from a container.	Drop capabilities, no privileged mode, RBAC, network policy.
Serverless abuse	Over-permissioned functions, injected event data.	Pacu	Function runs attacker logic / over-broad access.	Least-priv function roles, validate event input.

Audit/recon tools to recognize: ScoutSuite · Prowler · Pacu (AWS exploitation) · CloudBrute · kube-hunter

---

5 Host-Based Attacks & Privilege Escalation

Post-access work on a single host: turn a foothold into **SYSTEM/root**. Study Windows and Linux as parallel columns — the exam tests them side by side. Enumeration scripts (**PEAS**) find the path; **GTFOBins/LOLBAS** tell you how to abuse a binary.

Attack	What it is	Tool(s)	Indicator	Remediation
Win: unquoted service path	Space in an unquoted service `binPath` lets you plant a hijacking exe.	WinPEAS, PowerUp	Service path with spaces + writable dir.	Quote all service paths; fix ACLs.
Win: weak service/registry ACLs	Writable service config or autostart lets you swap the binary.	PowerUp, accesschk	Writable service/key by low-priv user.	Restrict permissions; least privilege.

Attack	What it is	Tool(s)	Indicator	Remediation
Win: DLL hijacking / search order	Drop a malicious DLL where an app loads it first.	ProcMon, WinPEAS	App loads attacker DLL.	Safe DLL search, signed loads, fix write perms.
Win: token impersonation	Abuse `SeImpersonate` to become SYSTEM ("Potato" attacks).	PrintSpoofer, JuicyPotato	SYSTEM shell from a service account.	Patch, limit impersonation privileges.
Win: UAC bypass / kernel exploit	Evade UAC or exploit an unpatched kernel driver.	UACMe, known CVE PoCs	Elevation without prompt / SYSTEM.	Patch, high UAC level, exploit protections.
Linux: SUID/SGID abuse	Misused SUID binaries run as owner (root).	LinPEAS, GTFOBins	`find / -perm -4000` lists abusable bins.	Remove needless SUID; audit binaries.
Linux: sudo misconfig	`sudo -l` reveals commands runnable as root and abusable.	GTFOBins	Sudo entry that spawns a shell.	Minimal sudoers, no wildcards, `NOEXEC`.
Linux: cron / PATH / capabilities	Writable cron scripts, relative PATH, or `cap_setuid` caps.	LinPEAS, `getcap`	Writable cron job or dangerous capability.	Absolute paths, restrict cron/caps.
Living off the land (LOLBins)	Use trusted built-in binaries to run/download/bypass.	LOLBAS / GTFOBins refs	certutil/regsvr32/bitsadmin misuse.	App allowlisting, block/monitor LOLBins.

Exam anchors: `find / -perm -4000` (Linux SUID hunt), `sudo -l` (sudo abuse), **unquoted service path** (the classic Windows privesc), and knowing **GTFOBins** = Linux / **LOLBAS** = Windows lookup references.

---

6 Authentication & Credential Attacks

Getting or reusing credentials. Two families: **cracking** (offline against hashes) and **reuse** (pass-the-hash/ticket, Kerberos abuse). Password *spraying* (one password, many users) beats brute force against lockout policies.

Attack	What it is	Tool(s)	Indicator	Remediation
Brute force / dictionary	Try many passwords against a login.	Hydra, Medusa, Ncrack	Successful auth; many failed attempts.	Lockout, MFA, rate limiting.
Password spraying	One common password across many accounts to	CrackMapExec, Hydra	A few successes spread across	MFA, smart lockout, ban

Attack	What it is	Tool(s)	Indicator	Remediation
	dodge lockout.		users.	common passwords.
Credential stuffing	Replay breached user:pass pairs elsewhere.	Custom scripts	Logins with reused breach creds.	MFA, breach-password checks.
Offline hash cracking	Crack dumped hashes with wordlists/rules/masks.	Hashcat, John	Plaintext recovered from hashes.	Strong slow hashing (bcrypt), long passphrases.
Pass-the-Hash	Authenticate with the NTLM hash — no plaintext needed.	Impacket, CrackMapExec, Mimikatz	Auth/session using a hash.	Credential Guard, limit local admin reuse, LAPS.
Kerberoasting	Request service tickets (SPNs) and crack them offline.	Rubeus, Impacket `GetUserSPNs`	Crackable TGS (RC4) hashes.	Long service-account passwords, gMSA, AES.
AS-REP roasting	Grab crackable data from accounts with pre-auth disabled.	Rubeus, Impacket `GetNPUsers`	AS-REP hashes for no-preauth users.	Require Kerberos pre-authentication.
Golden / Silver ticket	Forge TGT (krbtgt) or service ticket for persistent domain access.	Mimikatz, Impacket	Valid tickets you minted.	Rotate krbtgt twice, protect DCs, monitor.
AD attack-path mapping	Graph relationships to find the shortest path to Domain Admin.	BloodHound / SharpHound	Visualized privesc/lateral path.	Tier model, prune excessive rights.
Default / reused credentials	Vendor defaults and shared local admin passwords.	Manual, default-cred lists	Login with known defaults.	Change defaults, LAPS, unique creds.

Know the difference: Kerberoasting targets SPN service accounts (needs valid domain creds); **AS-REP roasting** targets accounts with pre-auth *disabled* (no creds needed). CompTIA tests that distinction.

7 Social Engineering & Physical Attacks

Targeting **people and premises** instead of systems. Know the delivery channels (phish/vish/smish), the influence principles behind them, and the physical intrusion techniques.

Attack	What it is	Tool(s)	Indicator	Remediation
Phishing (+ spear / whaling)	Deceptive email; spear = targeted, whaling = executives.	GoPhish, SET, Evilginx	Clicks, submitted creds, opened payloads.	Awareness training, email filtering, DMARC, MFA.

Attack	What it is	Tool(s)	Indicator	Remediation
Vishing / smishing	Phishing by voice call / SMS.	Spoofing services, SET	Info or action given over phone/text.	Verification procedures, callback policies.
Pretexting / impersonation	Invented scenario/identity to build trust and extract access.	OSINT (recon)	Target complies with the false premise.	Identity verification, need-to-know culture.
BEC	Compromise/spoof an exec to authorize fraudulent transfers.	Spoofing, lookalike domains	Fraudulent payment/data request.	Out-of-band approval, DMARC, dual authorization.
Watering hole	Compromise a site the target group frequents.	Exploit kit (concept)	Victims infected via a trusted site.	Patching, egress filtering, EDR.
Baiting / USB drop	Leave malicious media for a curious victim to plug in.	Rubber Ducky, malicious USB	Payload runs when device is used.	Disable autorun, port control, training.
Tailgating / piggybacking	Follow an authorized person through a secure door.	—	Unauthorized entry, no badge.	Mantraps, badge-in enforcement, guards.
Dumpster diving / shoulder surfing	Recover info from trash or by watching input.	—	Sensitive data recovered/observed.	Shredding, clean-desk, privacy screens.
Badge cloning / lock bypass	Clone RFID badges or bypass physical locks.	Proxmark3, Flipper, lockpicks	Cloned badge / bypassed lock works.	Encrypted badges, MFA doors, better locks.

Primary toolkit: SET (Social-Engineer Toolkit) GoPhish Evilginx (MFA-phishing proxy) King Phisher · recon fuels all of it (OSINT, theHarvester, Maltego).

8 Specialized Systems

Non-traditional targets: mobile, IoT, OT/ICS, and increasingly AI/ML. Recognition-level for most items — know the platform, the signature weakness, and one or two tools.

Target	What/typical weakness	Tool(s)	Indicator	Remediation
Mobile (Android/iOS)	Insecure storage, weak crypto, reverse-	MobSF, apktool, Frida, Objection	Secrets in app; runtime bypass works.	Encrypt storage, cert pinning, obfuscation, no secrets in app.

Target	What/typical weakness	Tool(s)	Indicator	Remediation
	engineerable apps, hooking.			
IoT / embedded	Default creds, unsigned firmware, exposed services.	Binwalk, Firmwalker	Extracted creds/keys from firmware.	Signed firmware, change defaults, network isolation.
Hardware interfaces	Debug ports (UART/JTAG/SPI) give console/memory access.	Bus Pirate, logic analyzer	Root shell over UART; memory dump.	Disable debug ports, secure boot, tamper protection.
OT / ICS / SCADA	Fragile legacy protocols (Modbus, DNP3) with no auth; safety-critical.	Modbus tools (read-only care!)	Unauthenticated read/write to PLCs.	Network segmentation, unidirectional gateways, careful testing.
AI / ML systems	Prompt injection, model/data poisoning, model extraction.	Manual prompt testing	Model ignores guardrails / leaks data.	Input/output filtering, guardrails, least-priv tool access.

OT/ICS caution is itself testable: these systems are **safety-critical and fragile**, so the exam-correct approach favors passive techniques, tight scope, and extreme care over aggressive scanning.

Master Tool Matrix

Drill this *both directions*: given the tool, name the attack; given the attack, name the tool. Recognition covers most exam items.

Tool	Surface	Use it for
Nmap	Network	Host discovery, port/service/version scan, NSE scripts.
Responder	Network	LLMNR/NBT-NS poisoning → capture NetNTLM hashes.
Impacket suite	Network / Auth	ntlmrelayx, secretsdump, GetUserSPNs, psexec, wmiexec.
Aircrack-ng suite	Wireless	Monitor, capture, deauth, crack WPA/WEP.
Burp Suite	Web / Cloud	Intercept, repeat, intrude, fuzz — the web workhorse.
sqlmap	Web	Automated SQL injection detection/exploitation.
gobuster / ffuf	Web	Directory, file, and subdomain brute forcing.
Nikto	Web	Quick web server misconfiguration scan.
Metasploit	Multi	Exploitation framework, payloads, post modules.
Hydra / Medusa	Auth	Online password brute force across many protocols.
Hashcat / John	Auth	Offline hash cracking (wordlist / rules / mask).
Mimikatz	Auth / Host	Dump creds/hashes/tickets; PtH; golden ticket.

Tool	Surface	Use it for
Rubeus	Auth	Kerberos abuse: roasting, ticket handling.
CrackMapExec / NetExec	Network / Auth	Spray, PtH, enumerate SMB/AD at scale.
BloodHound	Auth (AD)	Map attack paths to Domain Admin.
WinPEAS / LinPEAS	Host	Automated local privilege-escalation enumeration.
GTFOBins / LOLBAS	Host	Reference: abuse legit binaries (Linux / Windows).
Pacu / ScoutSuite / Prowler	Cloud	AWS exploitation / multi-cloud config auditing.
SET / GoPhish / Evilginx	Social	Phishing campaigns; MFA-phishing proxy.
MobSF / Frida / apktool	Mobile	Static/dynamic mobile app analysis and hooking.

→ How to Study This Domain (weekly loop)

- **One surface per session.** Take a single branch above, learn every attack in it with the four slots, then move on — don't grind the whole domain linearly.
- **Do it, don't just read it.** For a 35%-ish, attack-heavy domain, hands-on reps stick far better. Use PortSwigger's free Web Security Academy (web), TryHackMe / HackTheBox, and the CompTIA labs.
- **Active recall + spaced repetition.** Turn each row into an Anki card: prompt with the attack, recall the tool/indicator/fix. Let the app resurface what you miss.
- **Learn the "why."** Mechanism-level understanding is how you beat CompTIA's one-token-off distractors.
- **Compare-and-contrast pairs:** stored vs reflected XSS, SQLi vs command injection, Kerberoasting vs AS-REP roasting, reverse vs bind shell, WEP vs WPA cracking.
- **Map to frameworks:** OWASP Top 10 for web, MITRE ATT&CK for the rest — scaffolding beats loose lists.

Authorized use only. Every technique here is for penetration testing conducted **within a defined scope and signed rules of engagement**. Running these against systems you don't own or aren't explicitly authorized to test is illegal. As a tester you also document what you did (for cleanup) and pair each finding with the remediation shown above.

CompTIA PenTest+ PT0-003 · Domain 4 (Attacks & Exploits) · Organized by attack surface using the what → tool → indicator → remediation framework. Verify exact objectives and weightings against the official CompTIA exam objectives PDF.